Análise de arquivo suspeito

Share

exec.pyc

PYC

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando se a análise é defensiva

Vou começar consultando a skill de leitura de arquivos e depois inspecionar o arquivo.

Ler a skill de roteamento de leitura de arquivos antes de inspecionar o upload
Arquivo `.pyc` é bytecode Python compilado. Vou fazer apenas análise estática (sem executar nada). Primeiro, metadados e cabeçalho.

Ran 4 commands

Fiz apenas **análise estática**: o arquivo nunca foi executado, só desserializado com `marshal`, que lê a estrutura do bytecode sem rodar nada.

Passo a passo

1. **Formato.** É um bytecode compilado de Python (`.pyc`) de 54.248 bytes, gerado a partir de um `.py` de cerca de 42 KB. O *magic number* (`f3 0d 0d 0a`) indica Python 3.13. Como o interpretador disponível aqui é o 3.12, não consegui disassemblar as instruções de forma confiável, mas a estrutura do código ficou legível.
2. **Hashes**, para consulta em bases de ameaças:
   - MD5: `b9f92044394ee82f15a781c8bda4036e`
   - SHA-256: `90417bdfa064ed9c270fd877428787bf297da22ac1dc0b977cb45afbdb4216ce`
3. **Metadados.** O nome do arquivo-fonte gravado dentro do `.pyc` é uma sequência hexadecimal de 64 caracteres, no padrão de um SHA-256. Isso é comum em amostras vindas de repositórios e sandboxes de malware. É só um indício circunstancial.
4. **Imports.** O módulo importa criptografia AES, `win32api` / `win32con` / `ctypes` (APIs nativas do Windows), `smtplib` (e-mail), `socket` / `requests` (rede), `subprocess`, `psutil` e `threading`. Cada um é comum em software legítimo, mas juntos descrevem uma ferramenta que criptografa arquivos no Windows e se comunica com o exterior.
5. **Estrutura do código.** Os identificadores definidos no nível do módulo são o que decide:

- Constantes: `RANSOM_AMOUNT`, `ETH_ADDRESS` (carteira de Ethereum), `EXTENSION`, `C2_SERVER`
- Classes: `FileEncryptor`, `MBRLocker`, `ShadowCopyDeleter`, `ProcessHollowing`, `Persistence`, `AntiAnalysis`, `RansomNote`, `EmailSender`
- Classe principal: `LiushenRansomware`

Conclusão: o arquivo é malware, mais especificamente um ransomware para Windows, com confiança muito alta.

Nenhuma ferramenta benigna reúne valor de resgate, carteira de criptomoeda, servidor de comando e controle, criptografador de arquivos, bloqueio do MBR, remoção de cópias de sombra, *process hollowing*, persistência e evasão de análise. Não dá para saber a intenção do autor, se é uma amostra em circulação ou um projeto "educacional". Funcionalmente, porém, é malware e deve ser tratado como tal. A classificação se baseia na estrutura e nos identificadores, não na leitura da lógica instrução por instrução, e não cruzei o hash com bases de inteligência de ameaças.

Parei a análise aqui de propósito. Não vou descompilar nem detalhar como cada módulo funciona, porque o Claude não trabalha em código malicioso no claude.ai, mesmo com finalidade legítima. Se você é analista e acha que esse limite não faz sentido no seu caso, o botão de polegar para baixo envia esse feedback à Anthropic.

Para os próximos passos, não execute o arquivo fora de uma VM isolada. Consulte os hashes no VirusTotal ou no MalwareBazaar e, se precisar de análise dinâmica, use uma sandbox (ANY.RUN, Hybrid Analysis) ou um time de resposta a incidentes. Se ele já foi executado em alguma máquina, isole-a da rede imediatamente, preserve as evidências em vez de formatar, restaure a partir de backups offline e avise sua equipe de segurança. No Brasil, o CERT.br recebe notificações de incidentes.

Qual é a categoria principal deste malware?

Refinando a classificação como ransomware híbrido ▸

A categoria principal é **ransomware**, mais especificamente um **crypto-ransomware**: o ataque se baseia em criptografar os arquivos da vítima e exigir pagamento de resgate, aqui em criptomoeda (há uma carteira de Ethereum entre as constantes).

Pelos nomes das classes, ele também tem características secundárias: de *locker* (`MBRLocker`, que bloqueia o acesso ao sistema), de sabotagem da recuperação (`ShadowCopyDeleter`), de evasão e injeção (`AntiAnalysis`, `ProcessHollowing`), de persistência (`Persistence`) e de comunicação externa (`C2_SERVER`, `EmailSender`). Isso o aproxima de um ransomware "completo", que combina vários módulos num único pacote.

No framework MITRE ATT&CK, o comportamento principal se enquadra na tática **Impact**, técnica **T1486 (Data Encrypted for Impact)**, o código padrão para reportar esse

tipo de ameaça. Esse enquadramento vem dos identificadores do código, não de uma confirmação do comportamento em execução.

